Analyse d'impact relative à la protection des données (AIPD / DPIA)

LIDL COLLECT — ART. 35 RGPD

Référence : Art. 35 RGPD — Analyse d'impact relative à la protection des données Grille CNIL / EDPB : 9 critères — DPIA obligatoire si ≥ 2 critères pleinement remplis Dernière mise à jour : 2026-04-16

CONTEXTE

L'article 35 du RGPD impose une analyse d'impact lorsqu'un traitement est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes physiques. La CNIL a publié une liste de 9 critères permettant d'évaluer cette obligation. Si au moins 2 critères sont remplis, la DPIA est obligatoire.

Le présent document évalue chacun des 9 critères pour le projet Lidl Collect et constitue la DPIA conduite en réponse à l'obligation identifiée.

NOTE MÉTHODOLOGIQUE

La grille CNIL est binaire : chaque critère est soit rempli (compte pour 1), soit non rempli (compte pour 0). Un scoring intermédiaire ne correspond pas aux lignes directrices EDPB (WP248) et produirait un seuil de déclenchement artificiel. La grille ci-dessous applique un scoring strict.

GRILLE D'ÉVALUATION — 9 CRITÈRES CNIL

Critère 1 — Évaluation ou scoring (y compris profilage)

> Traitement qui évalue ou prédit des aspects de la personnalité, comportements, situations économiques, santé, préférences, localisation ou mouvements.

ÉLÉMENT	ÉVALUATION
Programme de fidélité	Comptage de points simple — pas de profilage comportemental. Le score de fidélité ne prédit ni ne classe les clients. ❌ Non rempli
Suivi des performances des Préparateurs (`global_score`)	Score synthétique calculé automatiquement à partir des commandes préparées, du temps moyen, du taux d'erreur et des signalements de rupture. C'est une **évaluation quantifiée et automatisée d'un employé**. Les lignes directrices EDPB (WP248) citent explicitement l'évaluation de la performance des employés comme exemple caractéristique de ce critère. ✅ Rempli
Géolocalisation	Utilisée à la volée côté client pour détecter le magasin le plus proche — non stockée. Pas d'historique de mouvements. ❌ Non rempli

Verdict : ✅ **Critère rempli.** Le `global_score` constitue un scoring individuel automatisé d'employés au sens des lignes directrices WP248. La portée est limitée au contexte professionnel, avec accès restreint aux rôles Manager et Administrateur, mais le critère est structurellement satisfait.

Critère 2 — Décision automatisée avec effet juridique ou similaire

> Traitement aboutissant à une décision automatisée produisant des effets juridiques ou affectant de façon significative la personne.

ÉLÉMENT	ÉVALUATION
Score de performance	Le `global_score` est calculé automatiquement et mis à disposition du Manager. Aucune décision automatique ne s'en suit : pas de licenciement automatique, pas de sanction sans intervention humaine. Le score est un outil d'aide à la décision managériale. ❌ Non rempli
Statuts de commande	Les statuts évoluent automatiquement (PENDING → IN_PREPARATION → READY) mais n'ont aucun effet juridique sur le client. ❌ Non rempli
Inactivité de compte	La désactivation après 2 ans d'inactivité est précédée d'une notification et d'un délai de réactivation de 30 jours — intervention humaine possible à chaque étape. ❌ Non rempli

Verdict : ❌ Critère non rempli

Critère 3 — Surveillance systématique

> Traitement utilisé pour observer, surveiller ou contrôler les personnes, y compris la collecte de données via des réseaux.

ÉLÉMENT	ÉVALUATION
Journal des actions système (AuditLog)	Toutes les actions sensibles de tous les utilisateurs sont journalisées : connexions, modifications de statut de commande, exercice de droits RGPD, tentatives d'accès non autorisées. C'est un monitoring systématique de l'activité de chaque utilisateur sur la plateforme. ✅ Rempli
Suivi de performance des Préparateurs	Suivi continu et automatisé des indicateurs d'activité professionnelle (volume de commandes traitées, temps moyen, taux d'erreur). C'est un monitoring systématique de l'activité individuelle. ✅ Rempli
Géolocalisation	Non stockée — pas de surveillance des mouvements hors-plateforme. ❌ Non rempli

Verdict : ✅ Critère rempli. La surveillance est bornée au contexte professionnel et aux actions sur la plateforme (pas de géolocalisation, pas de biométrie, pas de surveillance hors-service), mais elle est systématique : toutes les actions de tous les utilisateurs sont tracées. Les lignes directrices EDPB (WP248) retiennent ce critère dès lors que la surveillance couvre de manière non ponctuelle l'activité de personnes dans le cadre d'un service numérique.

Critère 4 — Données sensibles (Art. 9) ou données hautement personnelles

> Traitement portant sur des catégories particulières de données (santé, origine ethnique, opinions politiques, religion, orientation sexuelle, données génétiques, biométriques) ou des données pénales.

ÉLÉMENT	ÉVALUATION
Données clients	Nom, prénom, email, téléphone, adresse, historique de commandes. Aucune donnée de santé, biométrique, pénale, religieuse ou d'origine ethnique. ❌ Non rempli
Données de performance employés	Métriques opérationnelles (temps, volume, taux d'erreur). Pas de données sensibles au sens de l'Art. 9. ❌ Non rempli
Données de paiement	MVP : paiement en magasin ou simulé uniquement — aucune donnée de carte bancaire réelle ne transite ou n'est stockée. ❌ Non rempli

Verdict : ❌ Critère non rempli

Critère 5 — Données à grande échelle

> Le traitement porte sur un nombre important de personnes, sur une grande quantité de données, ou couvre une zone géographique étendue.

ÉLÉMENT	ÉVALUATION
Volume	Environ 500 utilisateurs actifs, environ 2 000 commandes par mois (périmètre prototype). Volume très limité. ❌ Non rempli
Périmètre géographique	1 magasin pilote (Saint-Martin-d'Hères, Isère)
Note de projection	En contexte de déploiement réel à l'échelle Lidl France (1 600 magasins, 46 000 salariés, 15 millions d'utilisateurs Lidl Plus), ce critère serait immédiatement rempli et déclencherait une nouvelle DPIA.

Verdict : ❌ Critère non rempli dans le cadre du prototype

Critère 6 — Croisement ou combinaison de jeux de données

> Traitement qui combine, recoupe ou agrège des données issues de plusieurs sources ou collectées à des fins différentes, au-delà des attentes raisonnables de la personne.

ÉLÉMENT	ÉVALUATION
Performance + identité Préparateur	La table `Performance` relie l'identifiant du préparateur à des métriques d'activité professionnelle. Ce croisement reste dans les attentes raisonnables d'un contrat de travail — le suivi de performance est une composante standard de la relation employeur-employé. ❌ Non rempli
Journal d'audit + identité utilisateur	Chaque action tracée est reliée à l'utilisateur qui l'a effectuée. Les utilisateurs d'un service numérique s'attendent raisonnablement à ce que leurs actions soient journalisées à des fins de sécurité. ❌ Non rempli
Client + commandes + fidélité	Combinaison dans les attentes raisonnables du service (l'utilisateur s'inscrit pour commander et accumuler des points). ❌ Non rempli

Verdict : ❌ Critère non rempli. Les croisements opérés demeurent dans les attentes raisonnables de chaque relation contractuelle. Le critère 6 cible les croisements inter-finalités qui surprendraient les personnes concernées — ce n'est pas le cas ici.

Critère 7 — Personnes vulnérables

> Traitement portant sur des personnes dont le consentement ne peut être donné librement, notamment les mineurs, les personnes sous tutelle, les personnes âgées.

ÉLÉMENT	ÉVALUATION
Mineurs	Service réservé aux majeurs (18+) — déclaration sur l'honneur à l'inscription. Pour les produits réglementés (alcool), vérification visuelle d'identité par l'employé Lidl au retrait. La vente de tabac en ligne est interdite en France (Art. L.3512-3 CSP) et exclue du catalogue. ❌ Non rempli
Employés en situation de subordination	Les salariés sont dans un rapport de subordination, mais le traitement de leurs données de performance reste dans le cadre légal du contrat de travail et du Code du travail. ❌ Non rempli au sens de l'Art. 35
Personnes âgées	La clientèle inclut des seniors, mais aucun traitement spécifique à leur situation n'est réalisé. ❌ Non rempli

Verdict : ❌ Critère non rempli

Critère 8 — Usage innovant ou nouvelles technologies

> Traitement faisant appel à des technologies ou usages nouveaux (IA, reconnaissance faciale, IoT, machine learning).

ÉLÉMENT	ÉVALUATION
Stack technologique	React, NestJS, PostgreSQL, Docker, Nginx, JWT — technologies standard et éprouvées, sans innovation technologique particulière. ❌ Non rempli
Intelligence artificielle / Machine learning	Aucun algorithme d'apprentissage automatique ou d'intelligence artificielle. ❌ Non rempli
Biométrie	Aucune donnée biométrique collectée ou traitée. ❌ Non rempli

Verdict : ❌ Critère non rempli

Critère 9 — Transfert hors Union européenne avec niveau de risque élevé

> Traitement impliquant des transferts de données vers un pays tiers dont le niveau de protection est jugé insuffisant, sans garanties appropriées.

ÉLÉMENT	ÉVALUATION
Base de données (Supabase)	Hébergée à Frankfurt, Allemagne (région AWS eu-central-1) — aucun transfert hors Union européenne. ❌ Non rempli
Notifications email et SMS (Brevo)	Serveurs AWS Irlande (EEE) et infrastructure France — aucun transfert hors EEE. ❌ Non rempli
Infrastructure applicative	Conteneurs Docker hébergés localement — aucun transfert hors UE. ❌ Non rempli

Verdict : ❌ Critère non rempli

TABLEAU RÉCAPITULATIF

#	CRITÈRE	STATUT	SCORE
1	Évaluation / scoring	✅ Rempli — score de performance automatisé des préparateurs	1
2	Décision automatisée à effet juridique	❌ Non rempli	0
3	Surveillance systématique	✅ Rempli — journal d'audit exhaustif + suivi de performance continu	1
4	Données sensibles (Art. 9)	❌ Non rempli	0
5	Grande échelle	❌ Non rempli (prototype — 1 magasin)	0
6	Croisement de données	❌ Non rempli — croisements dans les attentes raisonnables	0
7	Personnes vulnérables	❌ Non rempli	0
8	Technologies innovantes	❌ Non rempli	0
9	Transfert hors UE à risque élevé	❌ Non rempli — tous les prestataires hébergés dans l'EEE	0
	Total		**2 / 9**

CONCLUSION

> **La DPIA est obligatoire** : le seuil de 2 critères remplis est atteint (critères 1 et 3). Le présent document constitue la DPIA conduite en réponse à cette obligation.

Deux critères sur neuf sont pleinement remplis, déclenchant l'obligation légale prévue par l'article 35 du RGPD :

- **Critère 1** : le score de performance automatisé des préparateurs constitue une évaluation individuelle au sens des lignes directrices EDPB.
- **Critère 3** : la journalisation exhaustive des actions sur la plateforme, combinée au suivi continu de l'activité professionnelle des préparateurs, constitue une surveillance systématique.

ANALYSE DES RISQUES

RISQUE IDENTIFIÉ	PÉRIMÈTRE	MESURE DE MAÎTRISE	NIVEAU RÉSIDUEL
Utilisation du score de performance à des fins disciplinaires sans procédure contradictoire	Suivi employés	Aucune décision automatisée — toute décision RH requiert une intervention humaine explicite. Le score est un outil d'aide à la décision, pas une sanction.	**Faible**
Accès non autorisé aux scores individuels	Suivi employés	Accès strictement limité aux rôles Manager et Administrateur. L'employé ne peut consulter que ses propres indicateurs.	**Faible**
Conservation excessive des données de performance	Suivi employés	Durée de conservation bornée à 5 ans après la fin du contrat, conformément au Référentiel CNIL Ressources Humaines 2026.	**Faible**
Exploitation du journal d'audit à des fins étrangères à la sécurité	Journal système	Journal en écriture seule — aucune suppression possible. Accès réservé à l'Administrateur système. Conservation limitée à 1 an.	**Faible**
Ré-identification dans le journal d'audit après suppression de compte	Journal système	Pseudonymisation de l'identifiant de l'acteur (HMAC-SHA256) à la suppression du compte, avec clé de hachage stockée hors base de données.	**Résiduel documenté et accepté**
Fuite de données personnelles par cache serveur (routes API authentifiées)	Infrastructure	Séparation de la politique de cache : assets statiques mis en cache, réponses API authentifiées exclues du cache avec en-tête `Cache-Control: private, no-store`. Mesure corrective documentée et requise avant mise en production.	**Résiduel — correction requise avant production**
Absence d'information préalable des préparateurs sur le dispositif de suivi	Suivi employés	Obligation légale au titre de l'Art. L1222-4 du Code du travail — notice d'information à formaliser avant tout déploiement.	**À traiter avant production**

CONCLUSION DE L'ANALYSE : RISQUES RÉSIDUELS ACCEPTABLES

Les risques identifiés sont soit maîtrisés par les mesures techniques et organisationnelles en place, soit documentés comme risques résiduels tolérés avec mesure compensatoire connue. **La DPIA ne révèle pas de risque élevé non traité.** Le traitement peut être mis en œuvre sous réserve que :

1. La notice d'information aux préparateurs (Art. L1222-4 Code du travail) soit formalisée avant tout déploiement.
2. La séparation de la politique de cache Nginx (routes API authentifiées hors cache) soit implémentée avant mise en production.

En contexte de déploiement à l'échelle de Lidl France (multi-magasins, milliers d'employés), une consultation préalable du Comité Social et Économique serait requise avant déploiement du dispositif de suivi de performance (Art. L2312-38 Code du travail).

MESURES DE PROTECTION EN PLACE

MESURE	PÉRIMÈTRE	STATUT
Accès au score de performance limité aux rôles Manager et Administrateur	Suivi employés	✅ Implémenté
Aucune décision automatisée fondée sur le score de performance	Suivi employés	✅ Documenté et garanti par architecture
Pseudonymisation de l'identifiant de l'acteur à la suppression de compte	Journal d'audit	✅ Spécifié
Durée de conservation des données de performance limitée à 5 ans après fin de contrat	Suivi employés	✅ Documenté
Exclusion des routes API authentifiées du cache serveur	Infrastructure	⚠️ Correction documentée — implémentation requise avant production
Notice d'information des préparateurs (Art. L1222-4 Code du travail)	Suivi employés	⚠️ À formaliser avant production
Consultation CSE (périmètre production réelle multi-magasins uniquement)	Suivi employés	⚠️ Hors périmètre prototype — obligation identifiée

CONDITIONS DE RÉÉVALUATION

Une nouvelle DPIA devra être conduite si l'un des événements suivants se produit :

ÉVÉNEMENT DÉCLENCHEUR	CRITÈRE ACTIVÉ
Déploiement à plus de 1 000 utilisateurs actifs ou extension à plusieurs magasins	Critère 5 (grande échelle)
Ajout d'un algorithme de recommandation produits basé sur l'historique d'achat	Critères 1 et 8
Utilisation du score de performance pour déclencher automatiquement des alertes ou sanctions RH	Critère 2
Hébergement d'un prestataire hors UE sans garanties appropriées (CCT ou décision d'adéquation)	Critère 9
Ajout de données de santé, biométriques ou pénales	Critère 4
Croisement des données entre plusieurs sites avec finalités distinctes	Critères 5 et 6